

Bayou Cloud Services ITGC Audit Report

Report Date	July 27, 2026
Audit Period	January 1, 2026 through June 30, 2026
Prepared By	Sandesh Lama Tamang
Distribution	Portfolio demonstration - synthetic data only
Overall Conclusion	Partially Effective

Executive Summary

Bayou Cloud Services has foundational IT general controls in place, including user access administration, change ticketing, risk tracking, and backup operations. However, the review identified exceptions that reduce confidence in the operating effectiveness of access management, change management, and remediation governance.

The most significant issues were terminated users retaining active access, privileged or sensitive-system access without MFA, change records missing key approval/testing evidence, and overdue remediation items without consistent governance.

Scope

System	Purpose	Risk Relevance
Active Directory	Identity and privileged access management	Central authentication and administrator access
ERP	Financial transaction processing	Financial reporting and business operations
Financial System	General ledger and reporting	Sensitive financial data and reporting integrity
Payroll	Payroll processing	Sensitive employee and compensation data
Change Manager	Change ticketing and approval	Change authorization and audit trail
Backup Platform	Backup scheduling and restore evidence	Business continuity and recoverability

Procedures Performed

Area	Procedure Summary
Access Management	Reviewed full synthetic user access population for terminated users, dormant accounts, MFA gaps, excessive privileges, contractor elevated access, and duplicate records.
Change Management	Reviewed change population, selected targeted emergency changes and random samples, and tested for approval, testing evidence, implementation timing, and segregation of duties.
Risk Governance	Scored IT risks using likelihood, impact, and control effectiveness. Reviewed risk ownership, overdue mitigation, and residual exposure.
Operations	Reviewed evidence checklist for audit logging, vulnerability scans, backup logs, and restore-test documentation.

Findings Summary

Finding ID	Title	Severity	Control Area	Status
F-001	Terminated users retained active access	Critical	Access Management	Open
F-002	MFA not enforced for privileged and sensitive-system access	Critical	Access Management	Open
F-003	Change management records contain approval, testing, and SOD exceptions	High	Change Management	In Progress
F-004	Risk remediation governance is incomplete	High	Risk Governance	Open
F-005	Backup restore evidence is incomplete	Medium	Computer Operations	Planned

Detailed Findings

F-001: Terminated Users Retained Active Access

Severity	Critical
Criteria	NIST AC-2; SOC 2 CC6.2; COBIT DSS05
Condition	Two terminated users retained access to in-scope systems during the review. One account retained Payroll access and did not have MFA enabled.
Effect	Unauthorized access may remain available after employment ends, increasing the risk of data exposure, fraud, or misuse.
Recommendation	Disable terminated users immediately, reconcile HR termination records against all in-scope systems daily, and require evidence of access removal within 24 hours.
Management Response	IT Operations will implement a daily HR-to-IAM termination reconciliation and retain evidence of removal approvals.

F-002: MFA Not Enforced for Privileged and Sensitive-System Access

Severity	Critical
Criteria	NIST IA-2; NIST AC-6; SOC 2 CC6.1
Condition	MFA exceptions were identified for privileged or sensitive-system users, including Active Directory and Financial System access.
Effect	Compromised credentials could be used to access sensitive systems without a second authentication factor.
Recommendation	Enforce MFA for all privileged accounts and all access to ERP, Payroll, Financial System, and Active Directory. Review exceptions monthly and require CISO approval.
Management Response	Security Engineering will update conditional access policy and produce monthly MFA exception reporting.

F-003: Change Management Records Contain Approval, Testing, and SOD Exceptions

Severity	High
Criteria	NIST CM-3; SOC 2 CC7.1; COBIT BAI06
Condition	The change population included exceptions for missing approvals, implemented-before-approval timing, missing testing evidence, and segregation-of-duties conflicts.
Effect	Unauthorized or inadequately tested changes may be introduced into production, increasing the risk of outages, data integrity issues, and control failure.
Recommendation	Configure mandatory change ticket fields, prevent closure without approval and testing evidence, and require independent approval for implemented changes.
Management Response	The Change Manager will update workflow rules and perform monthly exception review.

F-004: Risk Remediation Governance Is Incomplete

Severity	High
Criteria	NIST RA-5; NIST SI-2; COBIT APO12
Condition	The risk register included overdue mitigations, one risk without an owner, and one risk without documented controls.
Effect	High-priority risks may remain unresolved without management visibility or accountability.
Recommendation	Assign risk owners, define escalation thresholds for overdue risks, and require management approval for accepted residual risk.
Management Response	The GRC owner will maintain a POA&M; tracker and review overdue items with leadership monthly.

F-005: Backup Restore Evidence Is Incomplete

Severity	Medium
Criteria	NIST CP-9; NIST CP-10; SOC 2 CC7.3
Condition	Backup job logs were available, but restore-test evidence did not include complete sign-off and validation results for all in-scope systems.
Effect	Management may not be able to demonstrate recoverability of critical systems during an audit or incident.
Recommendation	Perform quarterly restore tests for critical systems and retain screenshots, test results, approver sign-off, and issue remediation evidence.
Management Response	IT Operations will formalize quarterly restore testing and retain evidence in the audit repository.

Overall Conclusion

Bayou Cloud Services demonstrates meaningful progress toward ITGC and GRC maturity. The control environment should be considered partially effective until access, change, and remediation exceptions are corrected and retested. Priority should be given to terminated-user access removal, MFA enforcement, change workflow hardening, and POA&M; governance. All companies, users, systems, records, and evidence references in this report are fictional and do not represent a real client or employer.